SBOM vergleichen — Benutzeranleitung
Compare SBOM — User Guide

SCHUNK SBOM Tool for Windows · Version 1.2.2

Zweisprachig: Deutsch (Teil 1) · English (Part 2)

Teil 1 — Deutsch

1. Wofür ist der Vergleich?

Mit SBOM-Compare.html vergleichen Sie zwei CycloneDX-Dateien (.cdx.json): eine ältere Referenz (Baseline) und eine aktuelle Messung. Das Tool zeigt auf einen Blick, welche Software gleich geblieben ist, welche Versionen sich geändert haben und was neu hinzugekommen oder entfernt wurde.

Zusätzlich können genehmigte Versionsunterschiede hinterlegt werden — z. B. wenn ein Browser-Update erwartet und freigegeben ist.

2. Benötigte Dateien

- SBOM-Compare.html — im Tool-Ordner; Doppelklick oder „Öffnen mit“ Browser.
- Baseline: ältere .cdx.json (Referenz-Scan).
- Aktuell: neuere .cdx.json (aktueller Scan).
- Optional: SBOM-Approved-Differences.json mit Regeln für bekannte, freigegebene Versionsänderungen.

3. Schritt für Schritt: Vergleich starten

Schritt 1 — SBOM-Compare.html öffnen

Doppelklick auf SBOM-Compare.html. Edge oder Chrome empfohlen. Es ist keine Installation nötig — die Datei läuft vollständig lokal im Browser.

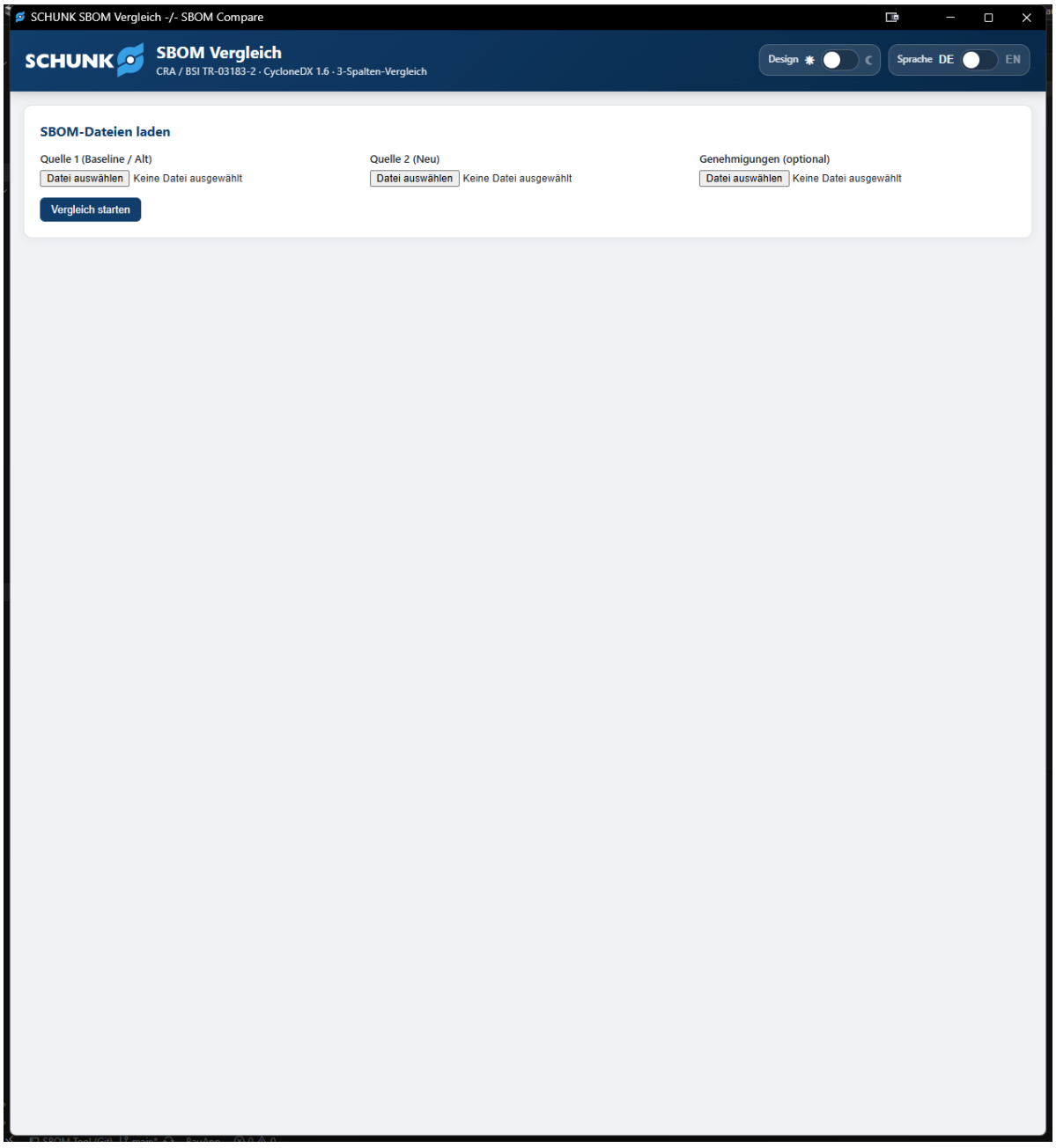


Abbildung 1: Dateiauswahl — Baseline, Aktuell, optional Genehmigungen

Schritt 2 — Baseline (Quelle 1) wählen

Klicken Sie bei „Quelle 1 / Baseline“ auf Datei wählen und laden Sie die ältere Referenz-SBOM (.cdx.json). Das ist der Stand, gegen den verglichen wird — z. B. das freigegebene Image vom letzten Quartal.

Schritt 3 — Aktuell (Quelle 2) wählen

Klicken Sie bei „Quelle 2 / Aktuell“ und laden Sie die neue SBOM. Nach Auswahl beider Dateien startet der Vergleich automatisch.

Schritt 4 — Optional: Genehmigungsregeln laden

Unter „Genehmigte Unterschiede (optional)“ können Sie eine JSON-Datei mit Regeln laden. Bereits bekannte, freigegebene Versionsänderungen werden dann als „Genehmigt“ (lila) statt „Version geändert“ (orange) angezeigt.

Schritt 5 — Ergebnis lesen

Die Vergleichsansicht zeigt Statistik oben und eine Liste aller Komponenten mit Farbcode. Nutzen Sie die Filter-Chips, um nur bestimmte Status anzuzeigen.

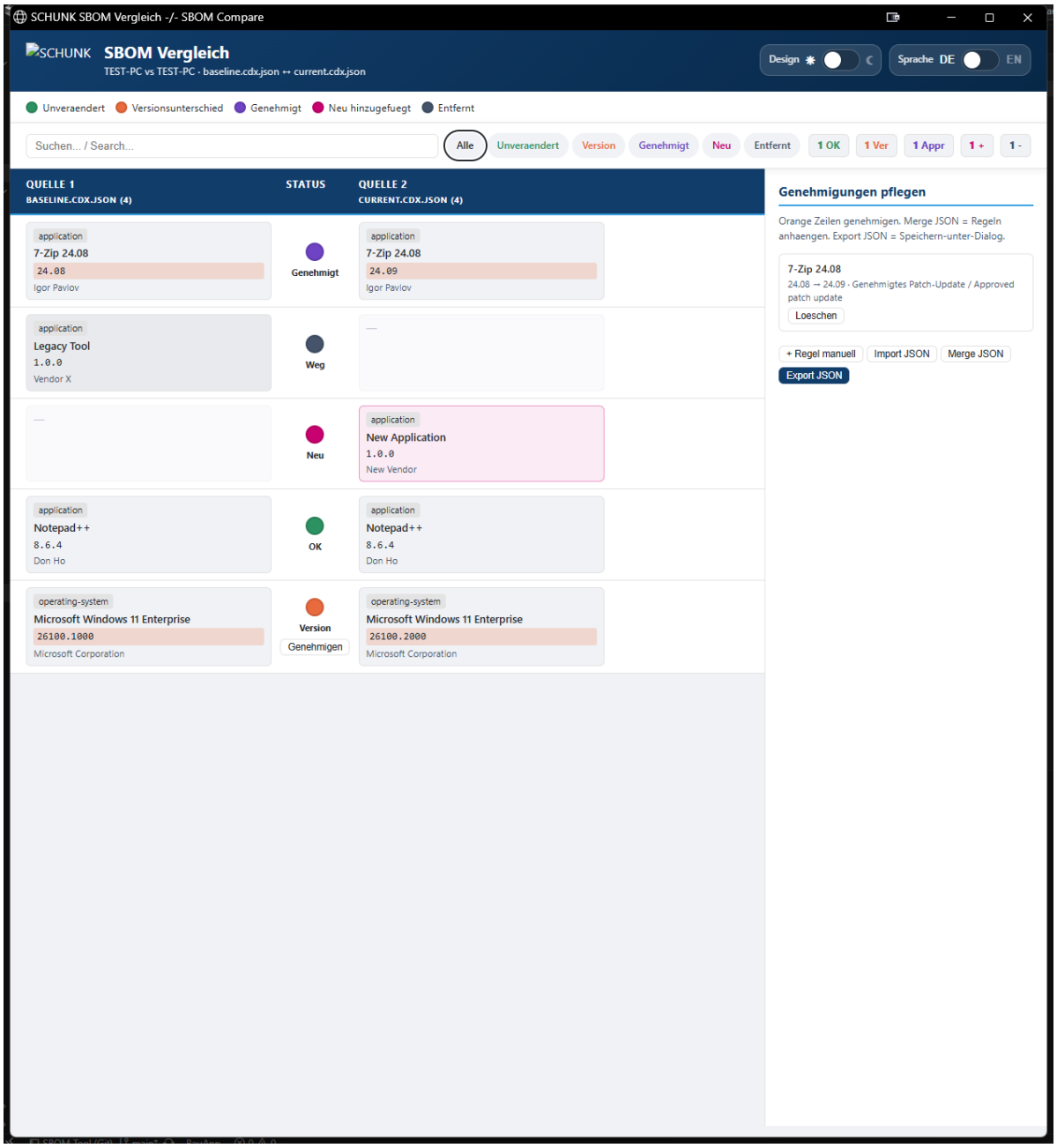


Abbildung 2: Vergleichsergebnis mit Statistik und farbigen Zeilen

4. Farben und Status — Bedeutung

- Grün / OK — Komponente unverändert (gleicher Name und gleiche Version).
- Orange / Version — Version hat sich geändert; Prüfung oder Genehmigung nötig.
- Lila / Genehmigt — Versionsänderung, aber durch eine Regel freigegeben.
- Blau / Neu — Komponente nur in der aktuellen SBOM (neu installiert).
- Rot / Weg — Komponente nur in der Baseline (deinstalliert oder fehlt).

Die Ampel oben fasst zusammen, ob der Vergleich „sauber“ ist oder Auffälligkeiten enthält. Orange Zeilen sollten Sie prüfen oder genehmigen.

5. Einzelne Änderung genehmigen

Schritt 1 — Orange Zeile finden

Filtern Sie optional mit dem Chip „Version“, um nur Versionsänderungen zu sehen.

Schritt 2 — Genehmigen klicken

Bei jeder orangen Zeile gibt es den Button „Genehmigen“. Ein Dialog öffnet sich.

Schritt 3 — Regel im Dialog festlegen

Im Dialog legen Sie fest:

- Softwarename — wird aus der Zeile übernommen.
- Von-Version / Zu-Version — der erlaubte Sprung (z. B. 24.08 → 24.09).
- Jede Version (anyVersion) — Häkchen setzen, wenn jede Versionsänderung dieses Produkts künftig erlaubt ist (z. B. Browser-Updates).
- Kommentar — interne Notiz (Warum freigegeben? Ticket-Nr.?).

Schritt 4 — Speichern im Dialog

Nach Bestätigung wird die Zeile lila („Genehmigt“) und die Regel erscheint in der Regelliste unten. Wichtig: Die Regel ist zunächst nur im Browser gespeichert (localStorage) — nicht automatisch in der JSON-Datei auf der Festplatte.

6. JSON-Regeln: Import, Merge und Export

Drei Buttons steuern die Datei SBOM-Approved-Differences.json:

Import JSON

Ersetzt alle aktuell geladenen Regeln durch den Inhalt der gewählten Datei. Nutzen Sie Import, wenn Sie eine vollständige Master-Datei vom Team übernehmen wollen.

Merge JSON

Fügt Regeln aus einer zweiten JSON-Datei hinzu. Bereits vorhandene Regeln (gleicher Name, Match-Typ und Versionen) werden übersprungen — keine Duplikate. Ideal, wenn Kollegen ihre Exporte einsammeln.

Export JSON

Öffnet den Speichern-unter-Dialog des Browsers (showSaveFilePicker). Sie wählen selbst Ordner und Dateiname — z. B. auf USB oder Netzlaufwerk. Falls der Dialog nicht verfügbar ist, startet ein normaler Download; Speicherort dann über Browser-Downloadeinstellungen.

7. Aufbau der JSON-Regeldatei

Jede Regel in rules[] hat typischerweise diese Felder:

- name — Softwarename wie in der SBOM (exakter Name).
- match — „exact“ (Standard) oder „wildcard“ für Muster.
- fromVersion / toVersion — erlaubter Sprung alt → neu.
- anyVersion: true — jede Versionsänderung für diesen Namen ist OK; fromVersion/toVersion werden dann ignoriert.
- comment — Freitext zur Dokumentation.

Beispiel: anyVersion für Microsoft Edge = alle Edge-Updates gelten als genehmigt. Beispiel ohne anyVersion: nur Sprung 7-Zip 24.08 → 24.09 ist erlaubt.

8. Team-Workflow (empfohlen)

- 1. Zentrale Master-Datei SBOM-Approved-Differences.json pflegen (z. B. im Git-Repo).
- 2. Jeder Nutzer lädt beim Vergleich diese Master-Datei (Import oder beim Start).
- 3. Neue Genehmigungen im Compare-Tool setzen.
- 4. Export JSON → Datei an Verantwortlichen senden oder auf Sammelfreigabe legen.
- 5. Verantwortlicher merged Exporte in die Master-Datei (Merge JSON oder manuell).
- 6. Aktualisierte Master-Datei an alle verteilen.

9. Oberfläche und Sprache

- DE/EN-Schalter — gesamte Oberfläche umschalten.
- Hell/Dunkel — Darstellungsmodus.
- Filter-Chips — Alle, OK, Version, Genehmigt, Neu, Weg.
- Suchfeld — Komponentenliste filtern.

10. Häufige Fragen

- Vergleich startet nicht — Beide .cdx.json ausgewählt? Dateien müssen CycloneDX vom Tool sein.
- Genehmigung nach Reload weg — Regeln waren nicht exportiert; Export JSON nicht vergessen.
- Merge meldet „0 added“ — Regel existiert bereits (Duplikat-Erkennung).
- Speichern-unter-Dialog fehlt — Anderen Browser testen oder Download-Fallback nutzen.
- Compare-HTML-Report — Für Dokumentation kann Compare-WindowsSBOM.ps1 einen statischen HTML-Report erzeugen; Endanwender nutzen SBOM-Compare.html interaktiv.

Part 2 — English

1. Purpose of compare

SBOM-Compare.html compares two CycloneDX files (.cdx.json): an older reference (baseline) and a current scan. You see at a glance what stayed the same, what changed version, and what was added or removed.

You can also maintain approved version differences — e.g. expected browser updates.

2. Required files

- SBOM-Compare.html — in tool folder; double-click or open with browser.
- Baseline: older .cdx.json (reference scan).
- Current: newer .cdx.json (current scan).
- Optional: SBOM-Approved-Differences.json with rules for known approved changes.

3. Step by step: run a compare

Step 1 — Open SBOM-Compare.html

Double-click SBOM-Compare.html. Edge or Chrome recommended. No install — runs fully local in the browser.

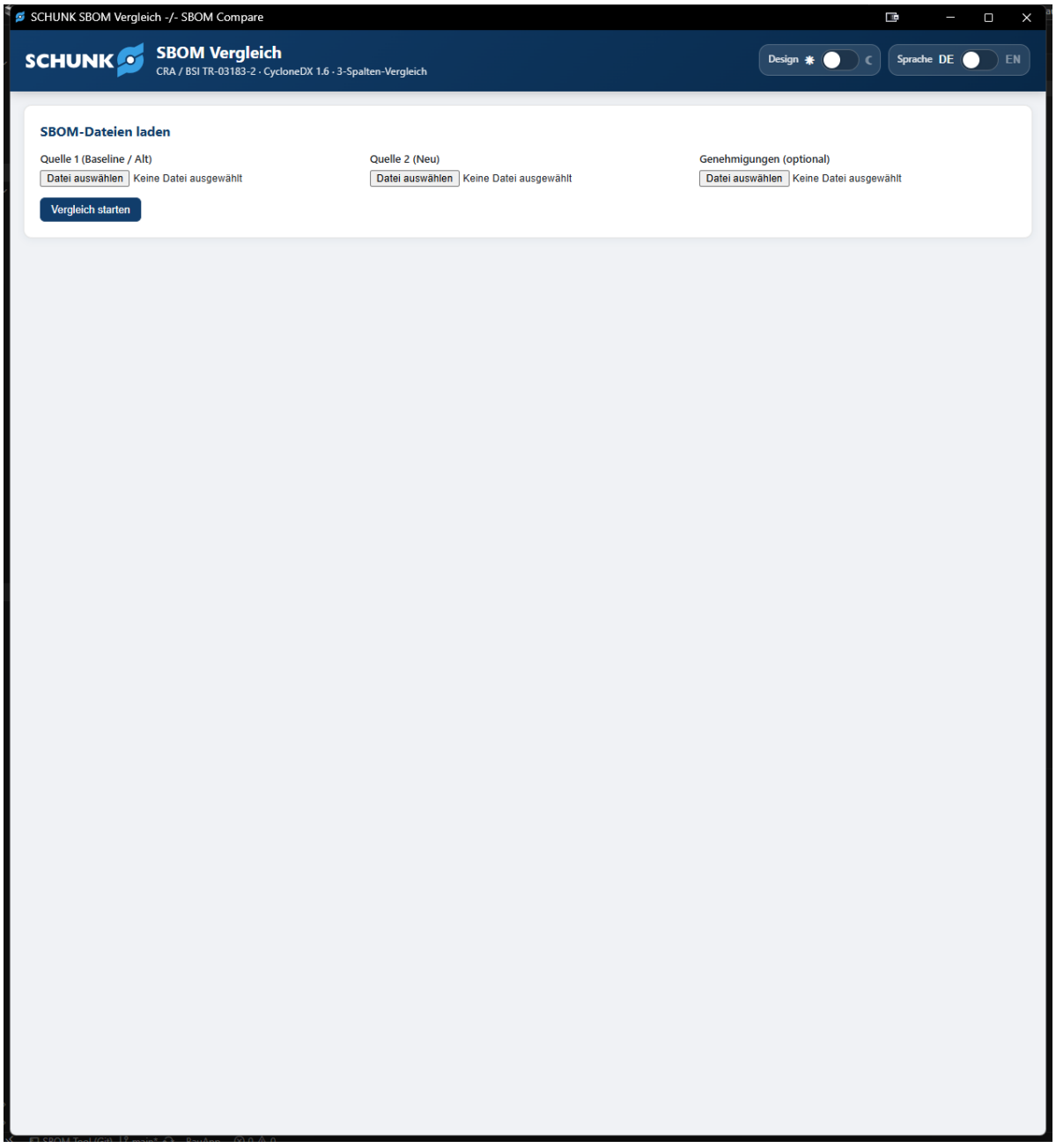


Figure 1: File picker — baseline, current, optional approvals

Step 2 — Select baseline (source 1)

Click choose file under “Source 1 / Baseline” and load the older reference SBOM. This is the approved state to compare against.

Step 3 — Select current (source 2)

Click under “Source 2 / Current” and load the new SBOM. After both files are selected, compare runs automatically.

Step 4 — Optional: load approval rules

Under “Approved differences (optional)” load a JSON rules file. Known approved version changes show as “Approved” (purple) instead of “Version changed” (orange).

Step 5 — Read the result

The view shows statistics and a component list with color coding. Use filter chips to show only certain statuses.

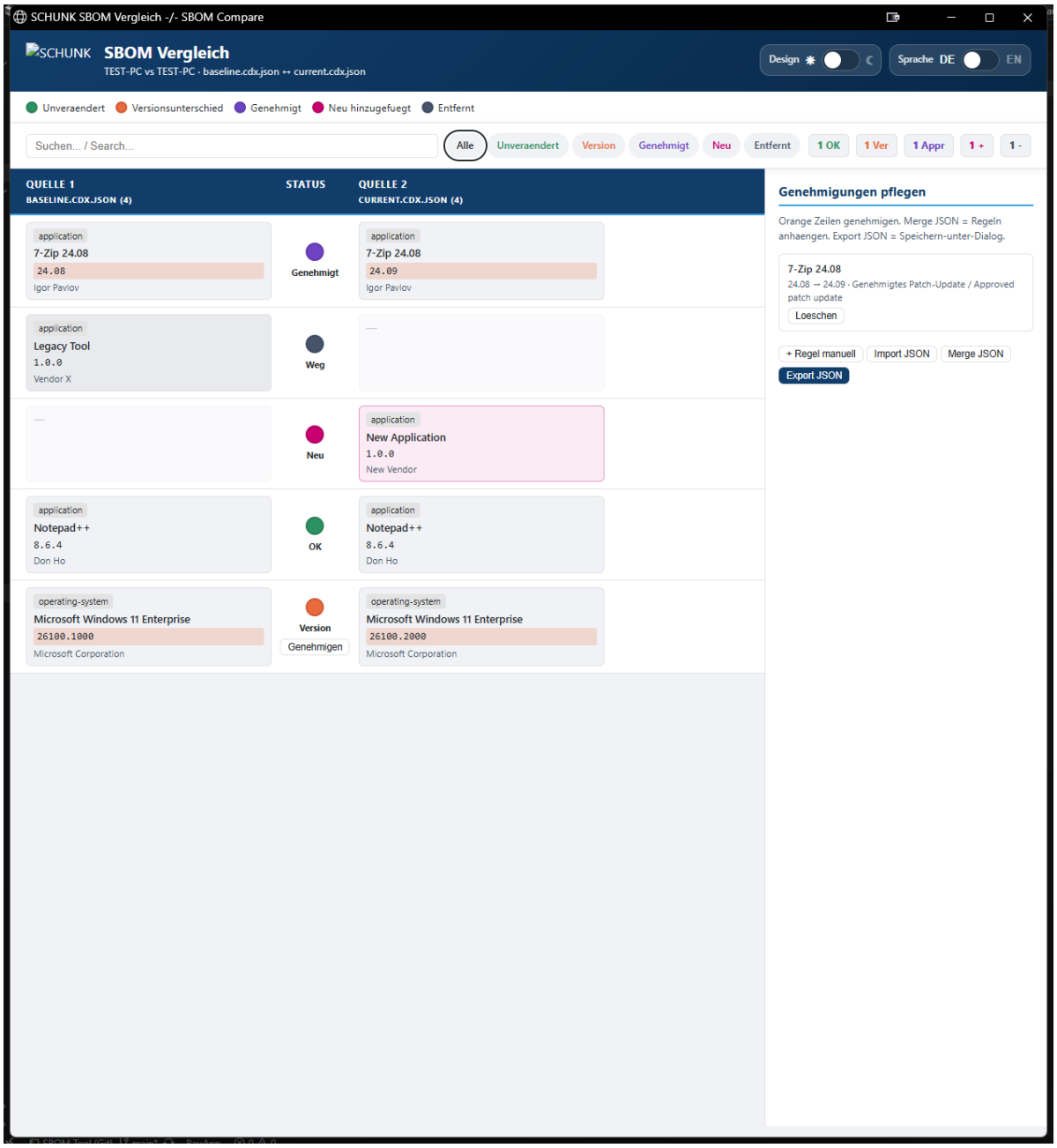


Figure 2: Compare result with statistics and colored rows

4. Colors and status

- Green / OK — unchanged (same name and version).
- Orange / Version — version changed; review or approve required.
- Purple / Approved — version change covered by a rule.
- Blue / New — only in current SBOM (newly installed).
- Red / Removed — only in baseline (uninstalled or missing).

5. Approve a single change

Step 1 — Find an orange row

Optionally filter with the “Version” chip.

Step 2 — Click Approve

Each orange row has an Approve button opening a dialog.

Step 3 — Set rule in dialog

- Software name — taken from the row.
- From / To version — allowed jump (e.g. 24.08 → 24.09).
- Any version (anyVersion) — check if any future version change for this product is OK.
- Comment — internal note (reason, ticket no.).

Step 4 — Confirm dialog

Row turns purple. Rule appears in the list below. Rules are stored in browser localStorage until you Export JSON.

6. JSON rules: Import, Merge, Export

Import JSON

Replaces all loaded rules with the selected file. Use for full master file from team.

Merge JSON

Appends rules from another file. Duplicates skipped. Use to collect colleague exports.

Export JSON

Opens browser Save As dialog. You choose folder and filename. Fallback: normal download if Save As API unavailable.

7. JSON rule file structure

- name — software name as in SBOM.
- match — “exact” or “wildcard”.
- fromVersion / toVersion — allowed old → new jump.
- anyVersion: true — any version change for this name is OK.
- comment — documentation text.

8. Team workflow (recommended)

- 1. Maintain central master SBOM-Approved-Differences.json.
- 2. Everyone loads master at compare (Import).
- 3. Add new approvals in Compare tool.
- 4. Export JSON → send to owner or shared folder.
- 5. Owner merges exports into master (Merge JSON or manual).
- 6. Distribute updated master to all.

9. UI and language

- DE/EN toggle — switch entire UI.
- Light/Dark — display mode.
- Filter chips — All, OK, Version, Approved, New, Removed.
- Search — filter component list.

10. FAQ

- Compare does not start — both .cdx.json selected?
- Approval gone after reload — forgot Export JSON.
- Merge reports “0 added” — rule already exists.
- No Save As dialog — try another browser or download fallback.